

ISC 2019 第七届互联网安全大会

以色列网络安全产业的创新机制介绍

奥伦·伊利米勒

以色列交通和道路安全部-信息安全负责人

小鹅助理



扫码添加小鹅助理，与数万科技圈人士
分享重量级活动PPT、干货培训课程、高端会议免费
门票



奥伦·伊利米勒
Oren Elimelech

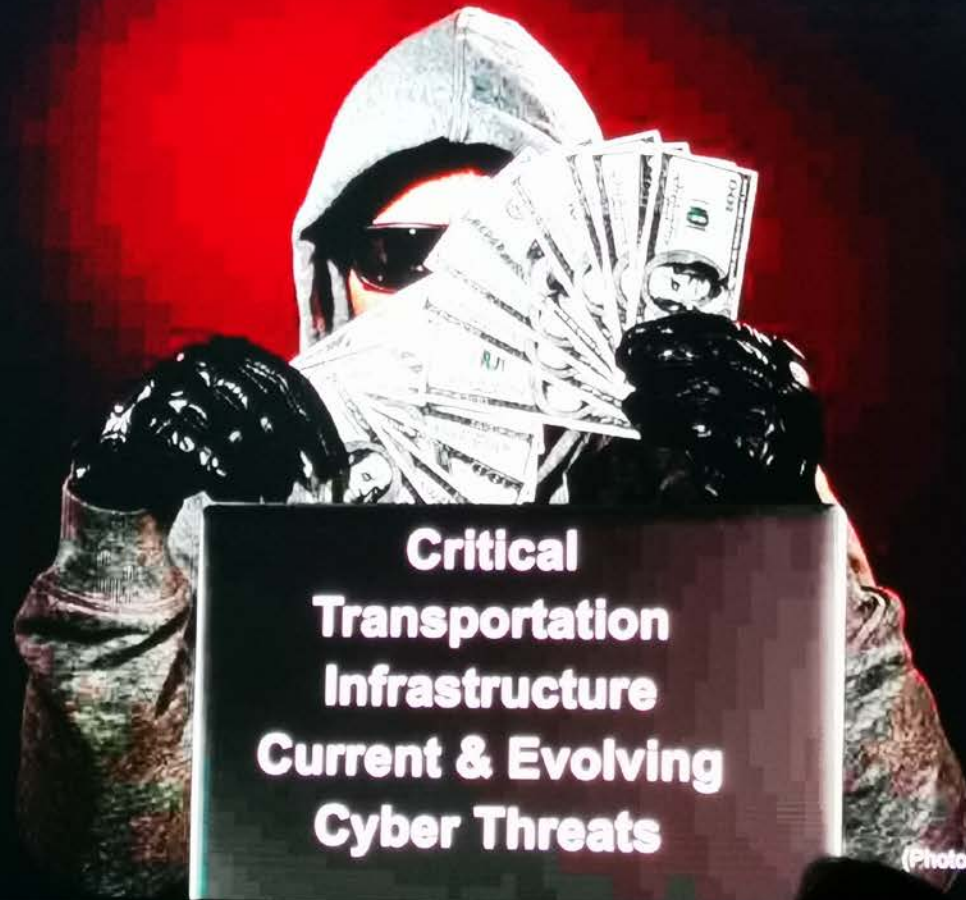
以色列交通和道路安全部-信息安全负责人
Cyber and Information Security Manager
at the Ministry of Transport and Road Safety in Israel

/Andrey Armyagov)





网络安全中心



**Critical
Transportation
Infrastructure
Current & Evolving
Cyber Threats**

(Photo: Shutterstock/Andrey Arnyagov)



Critical Transportation Infrastructure Current & Evolving Cyber Threats

International Security Conference 2019

19:50	Lisbon	Cancelled	22:20	Hong Kong	Cancelled
20:00	Islamabad	Cancelled	22:20	Lagos	Cancelled
20:15	Hong Kong	Cancelled	22:30	Cairo	Cancelled
20:25	Newark	Cancelled	22:30	Melbourne	Cancelled
20:25	Beijing	Cancelled		via: Hong Kong	
20:30	Singapore	Cancelled	22:30	Sydney	Cancelled
	Johannesburg	Cancelled		via: Hong Kong	
				via: Istanbul	



网络安全中心

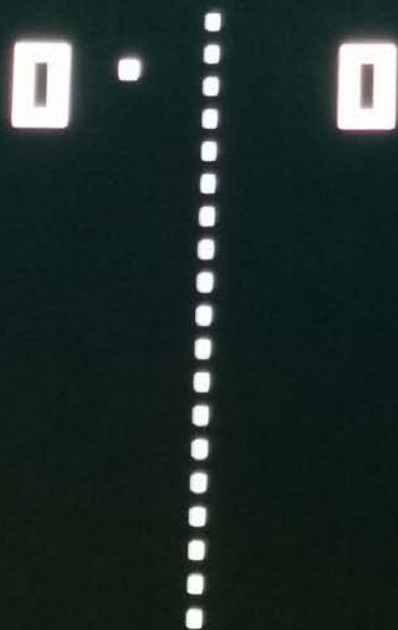
Transportation and Critical Infrastructure Current and Evolving Cyber Threats

Oren Ellmelech

CyberTeam360 CEO & Founder
Cybersecurity Adviser @ Ministry of Transport & Road Safety Israel
EU-IWGLTS Cybersecurity Working Group, Research Associate International
Counter Terrorism @ IDC, Israel
CISO, CISM, CRISC, CISA, CISSP, CEH, PCIP, VCP, EnCE, Security+, DFR



ATARI SECURITY...





Who are you?... About Myself

Oren Elimelech

Cyber Security & Privacy Researcher, Expert & Adviser



- Age 43 –, Computers & Electronics Practical Engineer
- Over 20 years of experience in advising, directing, consulting & hands-on assistance for enterprises & SMB organizations, governments & security industries:
 - **Cyber Security Adviser** – Israel's Ministry of Transport & Road Safety, Israel's National Lottery, Bank Jerusalem, Isracard, Shva, Universities & Fortune 500 Companies
 - **Cyber Security, Governance, Risk, Compliance and Strategy Consultant** – Bank Jerusalem, Bank Leumi, Clal, Hacshara, FNX, Teva, Yashir, EU Int. Working Group on Land Transportation
 - **Forensics Analyst & IS** - advising & supporting enterprises' IS & IT teams projects, vulnerability assessments, governance, compliance audits, regulatory checks, certification & accreditation for 27001, 22301, 27032, PCI-DSS, WLA-SCS, NIST, Banking, Insurance & others
- **Lecturer in professional courses:**
 - **NCSA, Military & Police** – Trainer in Tier I-II courses, investigator and consultant
 - **IDC-ICT, Technion Institute & See-Security** - Information Security, Risk & Cyber Security
 - **Microsoft** – IT User Groups, Conventions & Conférences
 - **ISACA** - Instructor & lecturer in Israel's official CISM courses
- **Active member in professional IS organizations:**
 - ISACA
 - ISSA
 - ISC²
 - OWASP
 - CSA
 - IAFPM
- Completed hundreds of projects around the world & my wife's IT issues...





Today's Agenda:

- **Cyber threats in Critical Infrastructure Overview**
- **Cybersecurity in Transportation sector**
 - **Aviation Threats & Attacks 2nd Tier & Avionics**
 - **Train Threats & Attacks**
 - **Public Transport Threats**
 - **Remote Exploitation of a Vehicle**
- **Protection framework for transportation**
- **Cyber insurance risk management**
- **Cyber education last line of defense**
- **Q & A**





Overview

- Imagine your country falling into darkness - transportation systems failing, financial systems crashing, life has come to a standstill, thousands are dying and unrest is breaking out as public services are failing throughout the country...
- This scenario is no longer an apocalyptic vision of an inspiring movie producer but has become a hard fact as this has already occurred recently with hostile hackers (backed by a nation) – infiltrating & shutting down the power grid



Overview

- Today - Our daily life, economic vitality, and national security depend on a stable, safe, and resilient Cyberspace
- In my work I usually focus and govern on Cybersecurity threats for enterprises and transportation



Transportation Cyber Threats

- The transportations segment includes many area:
 - Mass land transportation – Trains, Busses, Trucks etc.
 - Aviation transport – Planes, Airports among others
 - Naval transport – Ships, harbors, nav. system etc.
 - Traffic & Transit control – signal control, warning lights, road crossing illumination, tunnels and many more
 - Vehicle – connected vehicles via CAN bus, ECM, ECU

19:50	Lisbon	Cancelled	22:20	Hong Kong	Cancelled
20:00	Islamabad	Cancelled	22:20	Lagos	Cancelled
20:15	Hong Kong	Cancelled	22:30	Cairo	Cancelled
20:25	Newark	Cancelled	22:30	Melbourne	Cancelled
20:25	Beijing	Cancelled		via: Hong Kong	
20:30	Singapore	Cancelled	22:30	Sydney	Cancelled
	Johannesburg	Cancelled		via: Hong Kong	
				Tokyo	



Transportation Cyber Threats

- Most of the systems used in transportation are either ICS or SCADA systems
- They are used for: power control, emergency ventilation control, alarms, indicators, sensors, fire/intrusion detection, control/signaling, AVL, access control etc.

Avgångar		Departures	Terminal 4	
No	Destination	Flyg Flight	Öst Dest	Anmärkning Remark
110	Arvidsjobergs odl	Skarv	Autoskifcheck.	Cancelled
115	Skarv		Autoskifcheck.	Cancelled
120	Skarv		Autoskifcheck.	Cancelled
125	Skarv		Autoskifcheck.	Cancelled
130	Arvidsjobergs odl		Autoskifcheck.	Cancelled
135	Skarv			Final call
140	Skarv			Cancelled
145	Skarv			Cancelled
150	Skarv			Cancelled
155	Skarv			Cancelled
160	Skarv			Cancelled
165	Skarv			Cancelled
170	Skarv			Cancelled
175	Skarv			Cancelled
180	Skarv			Cancelled
185	Skarv			Cancelled
190	Skarv			Cancelled
195	Skarv			Cancelled
200	Skarv			Cancelled



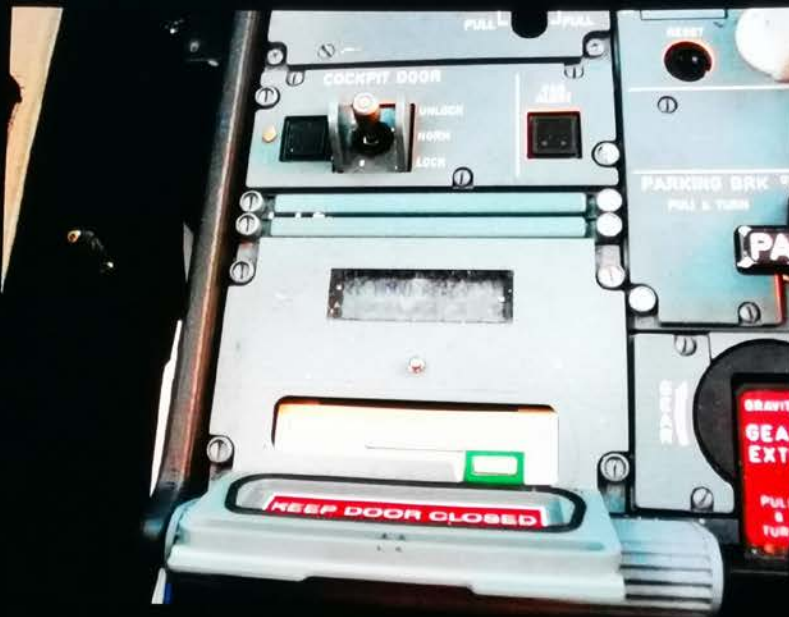
Areas of Compromise

- Most of the those system are vulnerable to Cyber attacks since most are not totally disconnected
 - Some are prone to physical access or even Radio data link or Cellular (Watch Tower, Black Box etc.)
 - Maintenance, firmware and software upgrades
 - Manifestation Impact – a vulnerability cascading effect reaching other systems & services affecting their compromising their availability & integrity
 - And the list is expanding on a daily basis...
-
- From the Security POV - One must ensure the **Confidentiality** (not necessarily security classified information), the **Integrity** and the **Availability** of information in OT & ICT systems



国际空间站

Firmware is updated via floppy or USB...





India's flight & plane big data crash

- On January 16th 2017 India's Directorate General of Civil Aviation (DGCA) - India's Aviation regulator loses all info related to pilots and aircraft safety after massive server crash
- The loss occurred following a massive software crash in August 2015
- Aviation experts say loss of flight data at such a massive scale may have serious implications not only on passenger safety but also on national security
- For Example September's Equifax data breach, actually began in May 2017...



第七届中国网络安全大会

LOT Airline Cyber Attack

- On June 21st operations were disrupted at Warsaw Chopin Airport by what LOT Polish Airlines said was a cyberattack on flight-planning computers. 10 LOT flights were canceled and some 15 others were grounded for several hours, affecting roughly 1,400 passengers

PRESS RELEASES



TODAY AFTERNOON LOT ENCOUNTERED IT ATTACK, THAT AFFECTED OUR GROUND OPERATION SYSTEMS.

21.06.2015

Today afternoon LOT encountered IT attack, that affected our ground operation systems. As a result we're not able to create flight plans and outbound flights from Warsaw are not able to depart. We'd like to underline, that it has no influence on plane systems. Aircrafts, that are already airborne will continue their flights. Planes with flight plans already filed will return to Warsaw normally.

< back



第七屆國際安全大會

United Airline vulnerabilities

- On July 8th 2015 – United Airlines issued a statement saying it suffered from “a network connectivity issue” – effecting 4,900 flights were impacted by the problem worldwide





British Airways Computer Problems

- Caused on September 6th 2016 – to over 200 flights to be delayed due to IT issues...





United Airlines IT Glitches...

- United flights delayed after computer glitch grounds US planes – Jan 23rd 2017





In-flight Wi-Fi is **'direct link'** to hackers

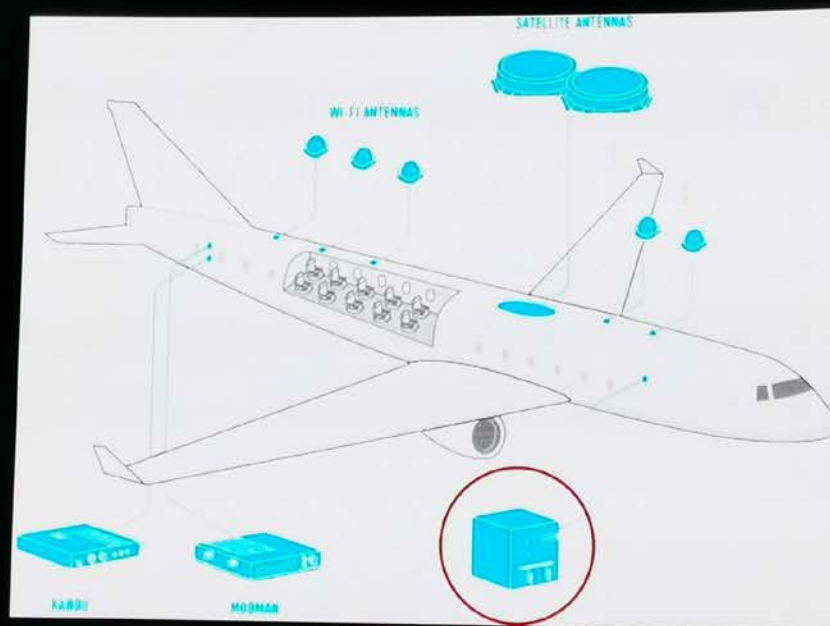
- GAO Report (The US Government Accountability Office), warns the FAA (Federal Aviation Administration): "FAA Needs a More Comprehensive Approach to Address Cybersecurity As Agency Transitions to NextGen" -

<http://www.gao.gov/assets/670/669627.pdf>



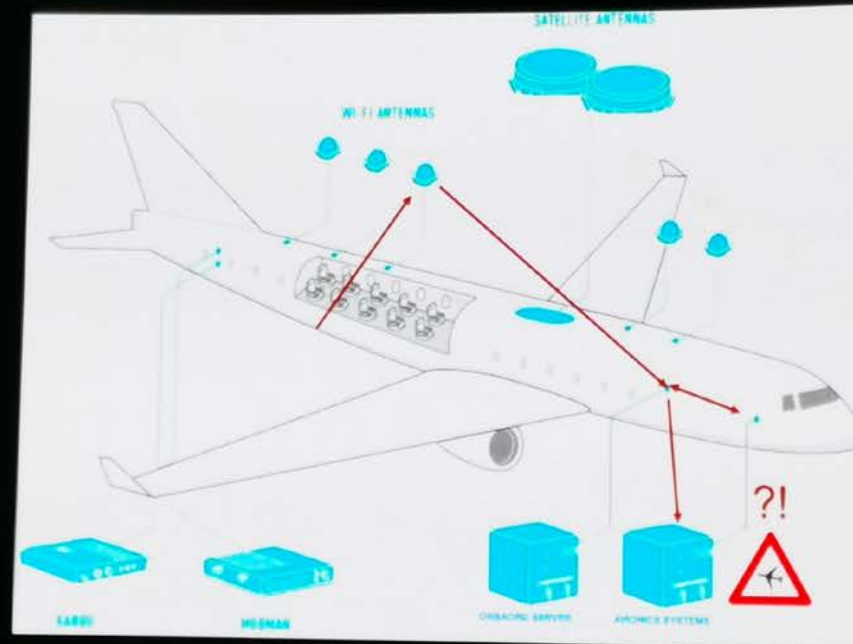


Plane In-Flight Wi-Fi Systems



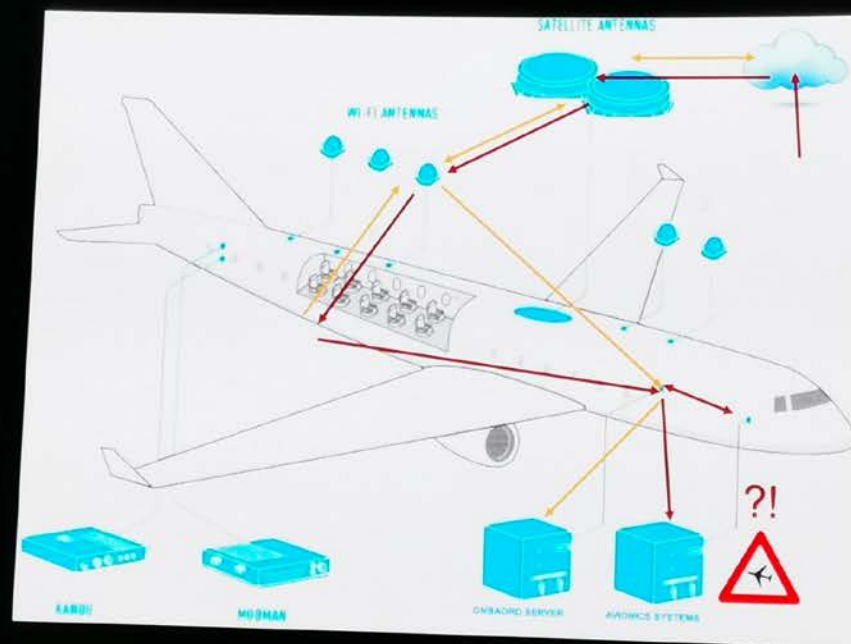


In-Flight Attack Scenario by a Passenger ?...





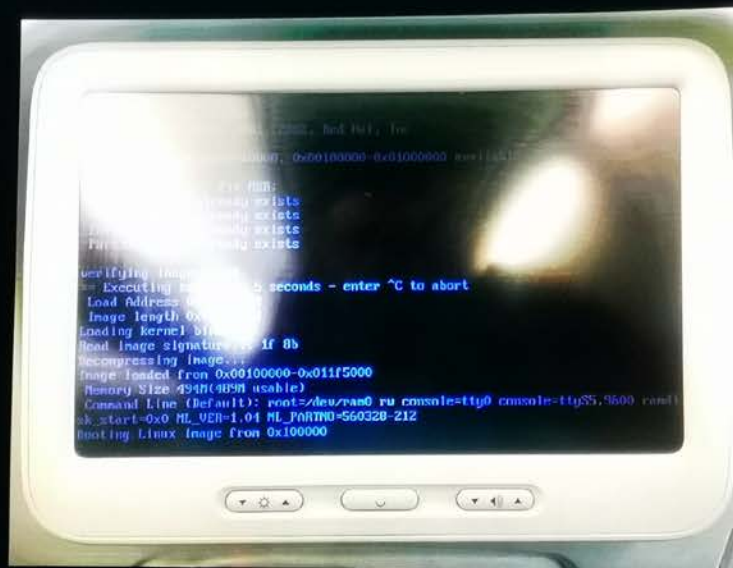
In-Fight Attack Scenario Via a Passenger ?...





ISC

So what is behind the In-Flight System ?...



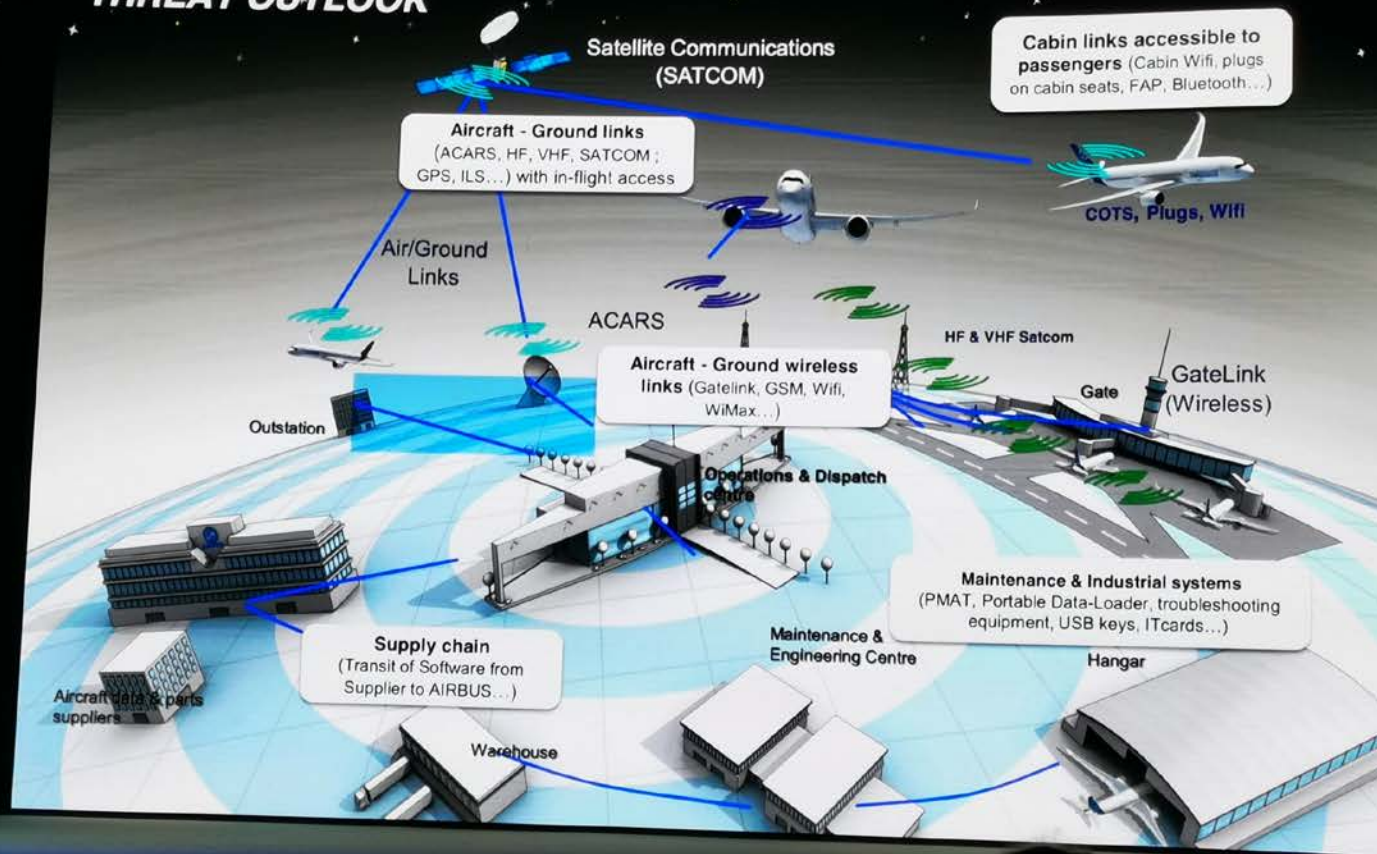


Airline Regulators Cyber Threat Strategy

- Following the recent event in US, Spain, Sweden & Poland aircraft infected with malware hazard, security breaches that provoke delays, loss of info and wave growing concern among the public
- The fear the terrorists one day are able to click on a laptop and crash a plane or make them disappear fro the radar screen
- Systems today are subject to an average of 1,000 attacks per month



THE COMPLEXITY OF AVIATION THREAT OUTLOOK





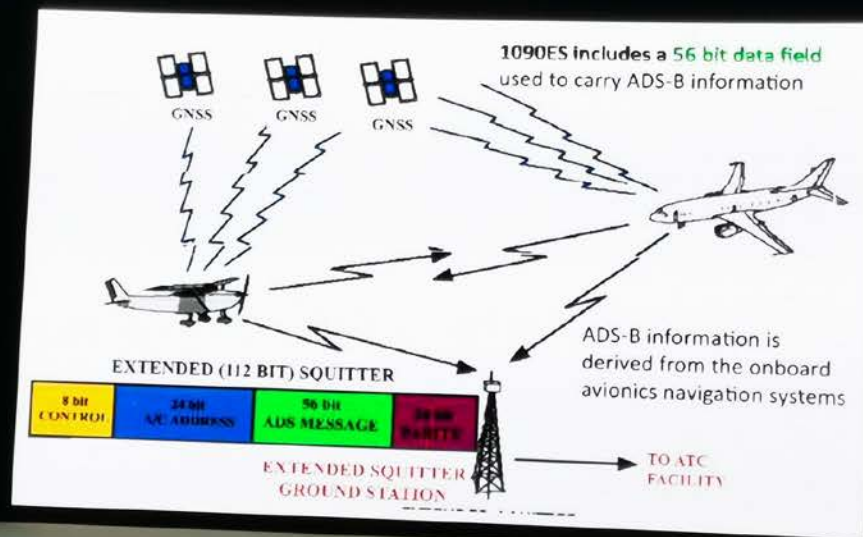
第七届中国国际海上安全大会



全中心

Automatic Dependent Surveillance Broadcast (ADS-B)

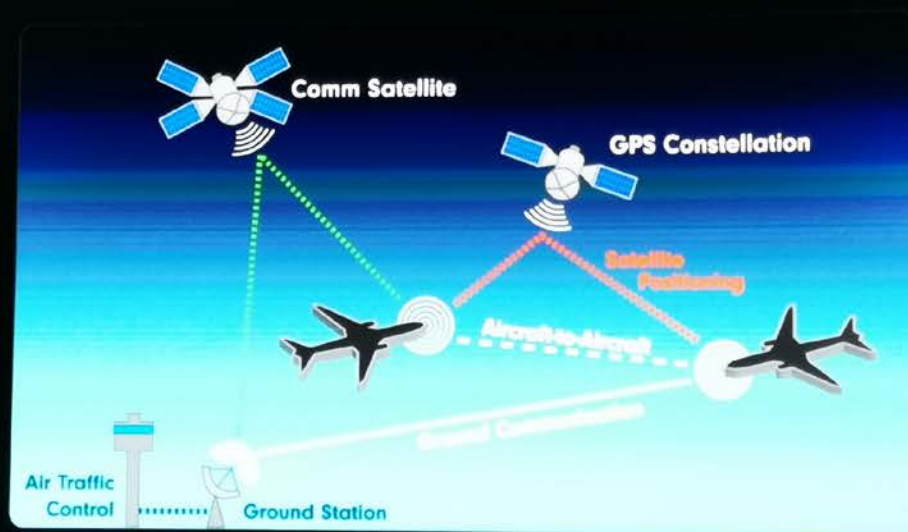
- ADS-B OUT and ADS-B IN
- Simplified Functional Diagram





Automatic Dependent Surveillance Broadcast (ADS-B)

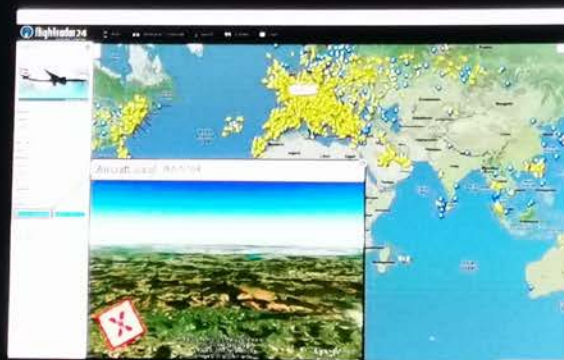
- ADS-B OUT and ADS-B IN
- Simplified Functional Diagram





Automatic Dependent Surveillance Broadcast (ADS-B)

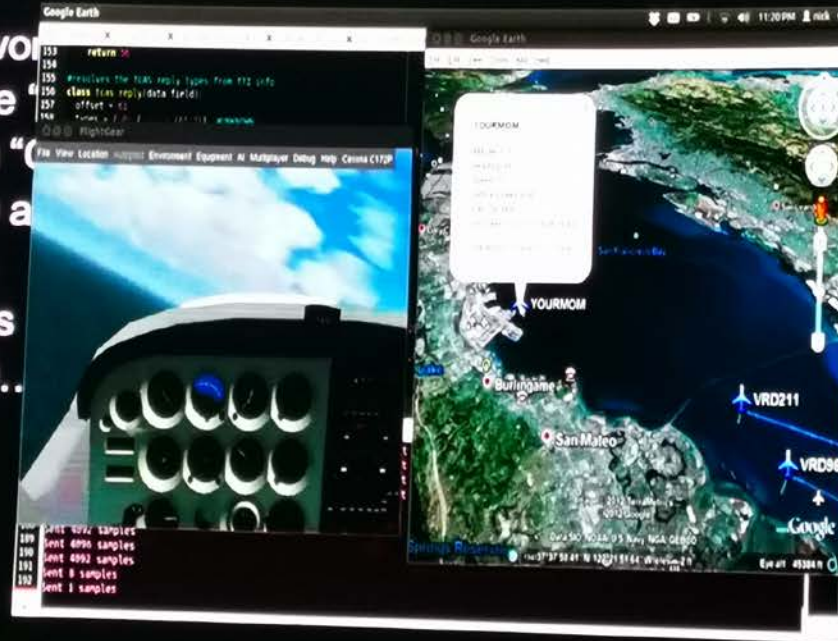
- With a \$2000 worth of store bought electronics an ADS-B beacon could be “spoofed” to show that a non-existent aircraft is coming – aka “Ghost Plane”
- This is possible as Air Traffic Control (ATC) systems have no way of verifying where messages are coming from...





Automatic Dependent Surveillance Broadcast (ADS-B)

- With a \$2000 worth of beacon could be is coming – aka “
- This is possible a way of verifying where messages are coming from..





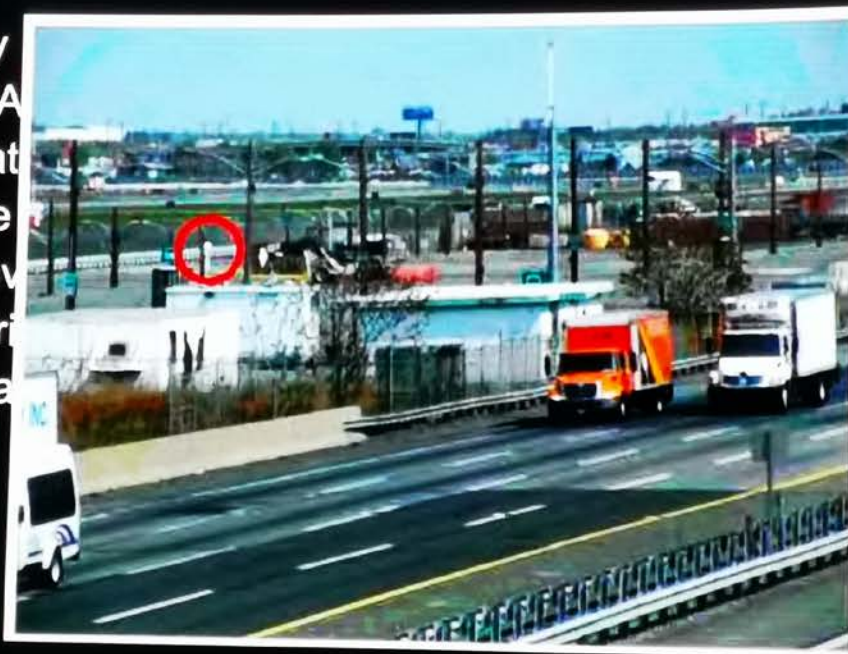
Ground Based Augmentation System (GBAS)

- Newark Liberty International Airport experienced sporadic outages of the GPS GBAS used for precision approach landing
- The ground station located approx. 300 feet away from the New Jersey Turnpike
- After an FAA investigation it was discovered that the cause was a passing truck driver on the turnpike using a widely available \$33 personal GPS jammer to avoid being tracked by his employer...



Ground Based Augmentation System (GBAS)

- Newark Liberty of the GPS GBAS
- The ground station Jersey Turnpike
- After an FAA investigation, a passing truck driver's personal GPS jammer...



outages

New

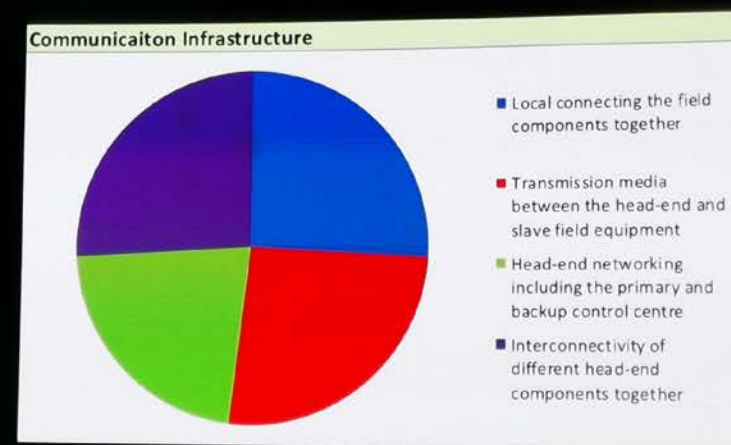
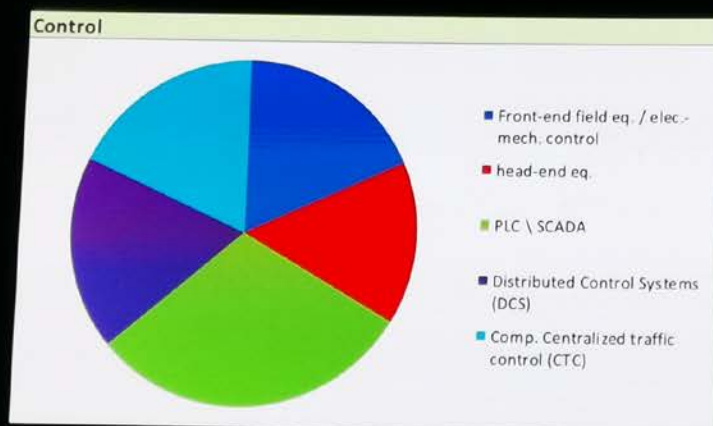
was a

\$33

er...



Cyber Train Security – IWGLTS Cyber Research

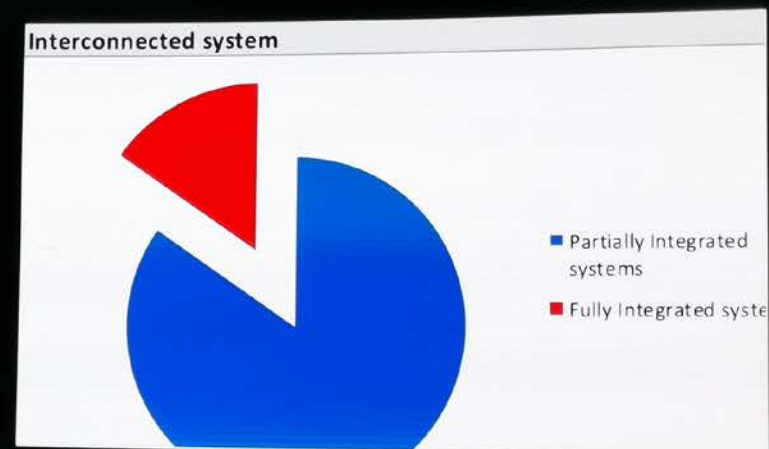
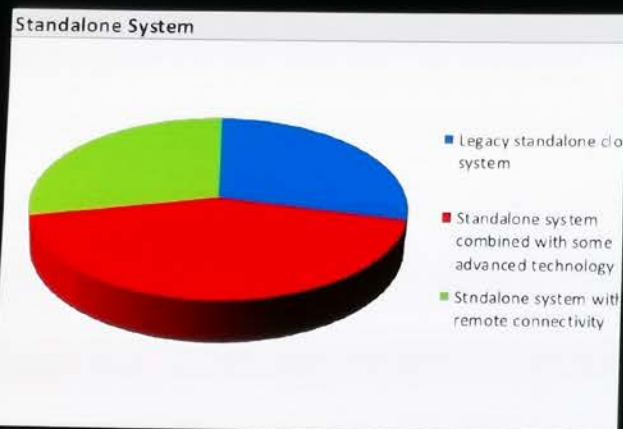




Cyber Train Security – IWGLTS Cyber Research



全中心





Metronit IL Bus

- Connected via Wi-Fi to the central metropolitan command-center in Haifa
- Has a direct RJ45 cable near the driver...
- Until recently on the same network segment – digital transit signs, traffic lights & more...



安全中心



第七屆國際資訊安全大會



網路安全中心

The growth and spread of connected digital technology

- Rapid technological change has resulted in many aspects of our lives being connected and affected by digital communications





第七屆國際安全大會



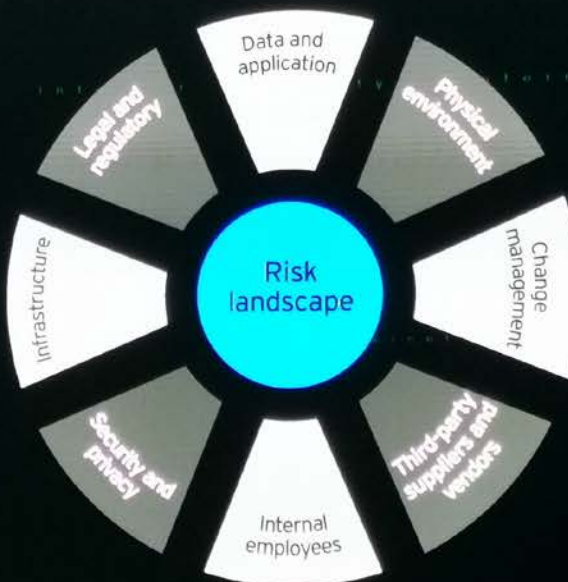
安全中心

HOW MANY STEPS
HAVE YOU
WALKED TODAY?



Cyber attacks Have transformed The risk landscape

- Most of today's business being done outside the organization's defensive fence
As a result, a cybersecurity system should also include the organization's "business ecosystem"





第七屆國際網路安全大會



全中心





CAN Bus Quick Intro

- **Controller Area Network (CAN)**
- **Developed by Bosch 1983-86 for automobile in-vehicle network**
- **Multi-drop, Multi-master serial bus providing communication between controllers, sensor and actuators**
- **Highly reliable and robust, well proven technology**
- **Inexpensive**
- **First car BMW series 8 - 1988**
- **100% car since 2008 user CAN bus**



Chrysler Jeep 2014 Remote Hacking



互联网安全中心





Chrysler Jeep 2014

- The Jeep Cherokee was chosen due to its apps are all bundled into the Harman is connected to both CAN buses in the 2014 Jeep Cherokee





车联网安全中心

Infotainment

- The telematics, Internet, radio, and Apps are all bundled into the Harman Uconnect system that comes with the 2014 Jeep Cherokee





Cyber Physical Features

- Lane Departure Warning (LDW+)
 - examines the lines on the road (i.e. paint) to detect if the Jeep is leaving the current lane, it will adjust the steering wheel to keep the vehicle in the current lane





Cyber Physical Features

- **Park Assist System (PAM)**
 - Permits the driver to effortlessly park the car without much driver interaction in various scenarios, such as parallel parking, backing into a space, etc.
- **The PAM technology played a key role in the hack**
 - Enabling to use this PAM to steer an automobile at high speed with CAN messages alone





Cyber Physical Features

- **Park Assist System (PAM)**
 - Permits the driver to effortlessly park the car without much driver interaction in various scenarios, such as parallel parking, backing into a space, etc.
- **The PAM technology played a key role in the hack**
 - Enabling to use this PAM to steer an automobile at high speed with CAN messages alone





Cyber Physical Features

- Other vulnerable systems
 - Tire Pressure Monitoring System (TPMS)
 - Passive Anti-Theft System (PATS)
 - Bluetooth
 - Radio Data System
 - WIFI
 - GPS
 - HVAC (Heating and Air Conditioning)
 - Display
 - Knobs

Internet Security Conference 2019

ISC

Internet Security Conference



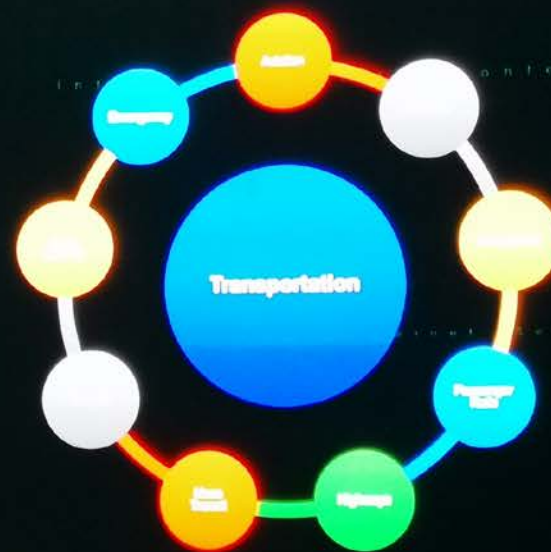
金中心





Ministry of Transport (MOT IL) – Sector specific

- Comprehensive general statutory authority
- Public and Private companies own and operate the Sector's critical infrastructure
- Participate with government establishing priorities and coordinate activities to achieve optimal effectiveness and efficiency



安全中心



Protection framework for transportation

Transportation segment includes many evolving cyber threats

- Today most systems used in transportation are critical either ICS or SCADA systems to 2nd-Tier open-systems inter-connected to other critical systems
- Used for: power control, emergency ventilation control, alarms, indicators, sensors, fire/intrusion detection, control/signalling, AVL, access control etc.
- Mass land transportation – Trains, Busses, Trucks etc.
- Aviation transport – Planes, Airports among others
- Naval transport – Ships, harbours/ports, navigation system etc.
- Traffic & Transit control – signal control, warning lights, road crossing, tunnels...
- Vehicle – connected vehicles via CAN bus, ECM, ECU



MOT Strategy Rational

Internet Security Conference 2019

- **The Cyber Rational**
 - Recent attacks on aviation & land transportation companies demonstrated high level cyber capabilities incorporating high cyber sophistication in conjunction with deep understanding of the business processes in those sectors
- Internet Security Conference
- **The Cyber Strategy**
 - The Security Process relies on multi-layered approach: Strategist (Business & Cyber), Threat Landscape (Methodology) and Operative



Multi-Layered Approach

- Ministry of Transport Business Landscape
- Threat Landscape & Risk Map
- All-Around Cyber Strategy – Business Driven
- Operative Recommendations

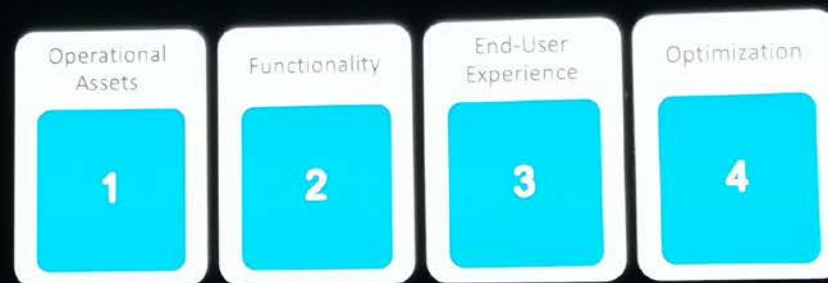


网络安全中心



All-around Cyber Strategy adjusted to Business Landscape assets (Business Driven)

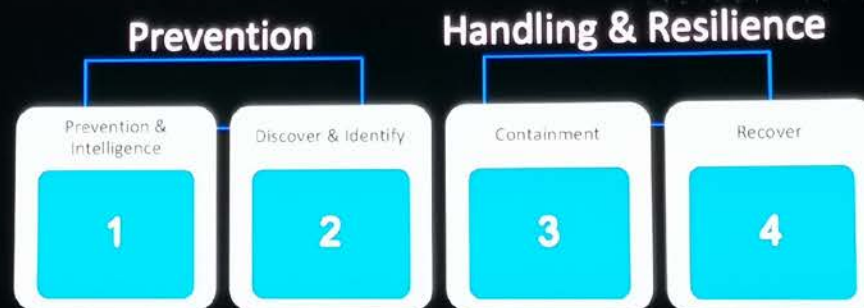
- **Operational Business Assets**
- **Functionality Prioritization**
- **Customer Experience**
- **Optimization**





All-around Cyber Strategy & Threat Landscape

- Threat Landscape & Risk Map
- Reducing significantly the probability for an incident (Prevent, Discover/Identify)
- Building Resilience and Fast Containment & Recovery Mechanisms if an incident occurs (Discover/Identify, Contain, Recovery)
- Referencing not only to an External Threats & attackers but also to Insider Threats





Analysing Threat Landscape facing Business Asset

- **Business Driven Top Down:**
 - **Damage to Operations & Productivity** – Availability & Integrity
 - **Sensitive Data Exposure** – Confidentiality
 - **Insider Threats** – Integrity Availability & Confidentiality
- **Bottom Up - over 100 Specific Cyber Scenarios**
- **Broad Cyber-Wide Scenario**

安全中心



第七屆國際資訊安全大會

Analysing Threat Landscape facing Business Assets

- Top Scenarios



网络安全中心

Insider Threat

- Theft using "User Impersonation" executing cmd on critical systems
- Theft using "Business Process Execution"
- Theft using "Client Impersonation" executing cmd on critical systems

Sensitive Data Exposure

- Data Leakage using "Operational Systems Access"
- Data Leakage using "Access to Databases" (not cri-sys path)
- Data Leakage using "Access to Interim Systems"

Operations Damage

- Modify / Delete Data in Systems (aka Data Tampering)
- Damage / Obstruction to 2nd-Tier Systems
- Damage to Resources Systems / Interim Systems

Broad Cyber Scenario

Dealing with a foot hold of an external attacker (AKA "Red Button") in each of the Top Scenarios



Protection framework for transportation

Transportation segment includes many evolving cyber threats

- Today most systems used in transportation are critical either ICS or SCADA systems to 2nd-Tier open-systems inter-connected to other critical systems
- Used for: power control, emergency ventilation control, alarms, indicators, sensors, fire/intrusion detection, control/signalling, AVL, access control etc.
- Mass land transportation – Trains, Busses, Trucks etc.
- Aviation transport – Planes, Airports among others
- Naval transport – Ships, harbours/ports, navigation system etc.
- Traffic & Transit control – signal control, warning lights, road crossing, tunnels...
- Vehicle – connected vehicles via CAN bus, ECM, ECU



What should we do next ?

So what do you need to do when you get back to the office tomorrow / next week?

- Find out what are the **key assets** in you organization that supports the business operation
- **What threats** can actually **damage your organization** and what is the easiest way to do so
- **Understand** what will be **the impact** to your organization – quantify it and check if you have the resources – today





Cyber insurance risk management





Cyber education last line of defense



Internet Security Conference

Internet Security Conference

Internet Security Conference



Questions ?

Internet Security Conference 2019

ISC

Please ask !

Internet Security Conference



Please Stay in touch

Oren Elimelech



OrenE@CyberTeam360.com

+972- (50)-5375365 / +972-3-9411324

linkedin.com/in/orenelm

小鹅助理



谢谢!

扫码添加小鹅助理，与数万科技圈人士
分享重量级活动PPT、干货培训课程、高端会议免费门票